

Threat Actor Profile: Pressure Chollima

BLUF

Pressure Chollima is a distinct offshoot of the larger operational umbrella of Democratic People's Republic of Korea (DPRK) cyber threat actors known as the Lazarus Group. Federal advisories and cyber vendors have characterized it as one of the most sophisticated active Advanced Persistent Threats (APTs). Pressure Chollima's history indicates a motivation of financial gain with a specific emphasis on cryptocurrency heists. The group has stolen billions of dollars worth of crypto since its emergence as a distinct subgroup. Its operations are alleged with moderate-high confidence to act as financial support for the interests of the North Korean regime.

Pressure Chollima relies heavily on social engineering techniques, commonly posing as recruiters for lucrative jobs on LinkedIn. These "recruiters" lure victims into interacting with malicious links or attachments which install trojanized programs. Once installed, their suite of malware tools begins to enumerate, conduct reconnaissance, harvest credentials, and move laterally. Actions on objective include private key theft, transaction redirects, and supply chain compromises. Pressure Chollima is best characterized by its blend of human-layer intrusion and privileged access compromise as its attack lifecycles places emphasis on social engineering, spear-phishing, and credential theft.

Executive Summary

Aliases: Lazarus Group, Labyrinth Chollima, Slow Pisces, UNC4899, TraderTraitor, Mata, Jade Sleet

Type: Nation-state

Objective: Financial and cryptocurrency asset theft

Targets: Centralized cryptocurrency exchanges in US, EUR, APAC, high-asset individual wallets, blockchain technology companies

First Observed: 2019

Last Observed: 2025

Confidence and Attribution

This analysis accepts a moderate/moderate-high level of confidence to the presented information. This analysis sources information from a variety of open-source locations including federal advisories, threat intelligence reports, forensic reports, and news articles. Attribution between Pressure Chollima and the DPRK's Lazarus Group is made with high confidence due to shared infrastructure, tactics, and malware. Due to this significant overlap, attack-specific attribution to Pressure Chollima vs. the broader Lazarus Group remains difficult. This analysis focuses strictly on cryptocurrency campaigns in order to focus specifically on probabilistic Pressure Chollima activity. Individual techniques are attributed to Pressure Chollima with moderate confidence.

Motivation

The Lazarus Group as a whole acts in favor of the DPRK's strategic interests. Pressure Chollima's operations specifically seek to acquire funds, most frequently in the form of cryptocurrency, to finance such interests. The sub-group's history heavily targets cryptocurrency exchanges and startups, individual asset-heavy wallets, and blockchain technology firms. Analysts assess cryptocurrency provides the actor with the ability to quickly obtain large amounts of funds which can be rapidly laundered.

Notable Campaigns

Operation Dream Job (2019-2022)

Targets lured with fake job recruitment offers on LinkedIn and enticed to download trojanized applications. The targets were primarily employees of cryptocurrency companies in DevOps, IT, and Sysadmin roles due to the higher probability of privileged access. Remote Access Trojans (RATs) would harvest system information, execute commands, and seek out crypto wallet keys.

A notable compromise of this operation involved a developer from Ginc0, a Japanese blockchain wallet and Web3 infrastructure firm, executing a malicious script allowing malware to enter the network. Attackers harvested SSH keys, credentials, and session cookies and moved laterally into Ginc0's internal systems. From there, attackers were able to breach an unencrypted communication channel linked to the Japanese crypto exchange DMM Bitcoin. Attackers were ultimately able

to exploit this access to divert 4,502.9 BTC in a fraudulent transaction leading to its ultimate shutdown.

Supply Chain Compromises (2023-2026)

The most damaging supply-chain attack was the Bybit heist in February 2025 which resulted in ~\$1.5B in ETH stolen. This attack has been coined as the most significant crypto heist to date. Attackers compromised a developer workstation in Bybit's third-party cold wallet provider SafeWallet at the application-layer, injecting malicious code into the frontend user interface. An exploit in Bybit's multi-signature process allowed the attackers to then detect transactions and modify them in real time, redirecting the funds to the attacker's wallet.

Many other supply chain compromises involved targets being lured to collaborate on infected GitHub repositories. The targets were primarily developers at crypto and fintech firms. Attackers would present themselves as software developers and contact the targets via social contact platforms like LinkedIn. The repositories contained malicious JavaScript packages sourced from npm as dependencies. The operation's objective was to directly steal crypto, if the developer had wallet access, or trojanize the company's software updates to infect downstream systems.

Attack Lifecycle

Initial compromise

Pressure Chollima relies heavily on social engineering for the initial stage of its attacks. Often posing as recruiters offering lucrative jobs on LinkedIn, the attackers utilize spear phishing to trick victims into executing trojanized applications on their machines ([T1566.001](#), [T1566.002](#))([DET0236](#)). Attackers will often target individuals employed with crypto or blockchain firms in DevOps, IT, or Sysadmin roles.

Malicious open-source packages have also been used as an entry point ([T1195.001](#))([DET0009](#)). In these attacks, Pressure Chollima was seen inviting developers to collaborate on GitHub repositories which contained malicious npm packages as dependencies.

Third-party vendor compromise has also been observed in highly consequential attacks ([T1199](#))([DET0488](#)). In the \$1.5B Bybit heist, attackers compromised an exploit in the exchange's third-party cold wallet provider SafeWallet. This gave the

attackers access to Bybit transactions without directly engaging Bybit's infrastructure.

Establish foothold

These executed applications contain malicious update routines which communicate with a C2 URL ([T1071.001](#))([DET0027](#)). The C2 server can then send an encrypted second stage payload that the application would decrypt and execute, further propagating malware ([T1001.003](#))([DET0470](#)).

This phase will also often include the staging of malware packages for future use. Pressure Chollima stages RN Loader early to deliver the additional payload RN Stealer later ([T1105](#))([DET0060](#)).

Escalate privileges

Pressure Chollima generally relies on credential harvesting from the compromised host and AWS session token theft for privilege escalation ([T1555](#), [T1539](#), [T1528](#))([DET0430](#), [DET0509](#), [DET0515](#)). Cloud tokens are a preferred method as it prevents the need to crack passwords and cloud resources are often a target for reconnaissance and lateral movement.

Internal recon

Reconnaissance is often focused on the enumeration of AWS and IAM resources and configurations. During recon, attackers conduct storage, process, user, and system discoveries ([T1680](#), [T1057](#), [T1082](#))([DET0188](#), [DET0034](#), [DET0525](#)). Malware may be used to check registry keys in HKCU and HKLM to determine if certain applications are present ([T1012](#))([DET0209](#)). Other malware has also been seen scanning for HKEY_CURRENT_USER\Software\Bitcoin\Bitcoin-Qt.

Lateral movement

AWS session tokens are often used to allow the attackers to pivot from compromised endpoints into cloud environments. Once achieved, attackers further pivot within AWS environments to reach IAM and asset-management functions.

Internal spear phishing is also utilized as phishing remains a favored access method of the group ([T1534](#))([DET0054](#)).

Mandiant has noted consistent use of ExpressVPN egress infrastructure combines with Kali Linux user-agent strings when operating hijacked AWS sessions is a core operational fingerprint of Pressure Chollima.

Persistence

More traditional persistence methods have been seen with the compromise of startup processes to maintain persistence, namely by loading malicious code into a startup folder or by adding a Registry Run key ([T1547.001](#))([DET0365](#)). Pressure Chollima may also rely on scheduled tasks to periodically execute remote scripts ([T1053.005](#))([DET0441](#)).

In the case of the SafeWallet/Bybit compromise, persistence was observed at the application layer by injecting malicious JavaScript directly into production, S3-hosted front-end code and left dormant until a specific high-value transaction occurred ([T1195.002](#), [T1554](#))([DET0309](#), [DET0336](#)). Supply chain compromises like this are difficult to defend against as they target trusted third parties.

Actions on objective

The final fund acquisition event varies based on the target. Pressure Chollima has been seen directly extracting funds, manipulating/redirecting transactions, and fully hijacking signature protocols ([T1657](#), [T1565.002](#))([DET0495](#), [DET0254](#)). In any case, all events are followed by rapid laundering.

Defender Recommendations

Attacks by this APT are rapid and require adequate measures to prevent.

- Educate users on social engineering and phishing
- Implement Endpoint protection security suites
- Closely monitor and potentially block connections to newly registered domains
- Scan email attachments and links
- Utilize application allowlisting to prevent unapproved programs from executing
- Utilize defense in depth and least privilege

- Segment networks to limit lateral movement
- Enforce MFA and credential requirements, consider hardware-backed MFA for privileged accounts
- Strict patch management

Detection Strategies

- Monitor for abnormal AWS API activity, including anomalous AWS session activity from consumer VPN egress combined with Kali Linux markers
- Alert on IAM privilege escalation with no business justification
- Alert on session token reuse
- Correlate cloud session locations with user baselines and alert on anomalies
- Develop incident response processes which facilitate rapid containment in the event of a suspected breach

Appendix: IOCs

Network IOCs

146.19.173.125	38.132.124.88	198.244.135.250
23.227.202.54	88.119.174.148	
contortonset[.]com	primerosauxiliosperu[.]c om	basketsaulte[.]com
relysudden[.]com	rentedpushy[.]com	prontoposer[.]com

Endpoint IOCs

65baa3c1a22052fe1f70c9d2cbe11de4	6d8194c003d0025fa92fbcbf2eadb6d1
155597a7985cb8f7a6e748e5e108f637	6d8194c003d0025fa92fbcbf2eadb6d1
39a421ea89035ffcc3dea0cd0f10964e	48eaf2a7e97189709fb3789f0c662e1c
27db0f17282a4c4507266f3c4d9c4527	b0e0e0d258fcd55d3cc5af2b4669e014
6d8194c003d0025fa92fbcbf2eadb6d1	15bfe67e912f224faef9c7f6968279c6

Ethereum addresses

0x51E9d833Ecae4E8D9D8Be17300AEE6 D3398C135D	0xfa3FcCCB897079fD83bfBA690E7D47E b402d6c49
0x96244D83DC15d36847C35209bBDc5b dDE9bEc3D8	0xFc926659Dd8808f6e3e0a8d61B20B87 1F3Fa6465
0x83c7678492D623fb98834F0fbc2E7b7 f5Af8950	0xb172F7e99452446f18FF49A71bfEeCf0 873003b4
0x83Ef5E80faD88288F770152875Ab0bb1 6641a09E	0x6d46bd3AfF100f23C194e5312f935079 78a6DC91
0xAF620E6d32B1c67f3396EF5d2F7d764 2Dc2e6CE9	0xf0a16603289eAF35F64077Ba3681af41 194a1c09
0x3A21F4E6Bbe527D347ca7c157F4233c 935779847	0x23Db729908137cb60852f2936D2b5c6 De0e1c887

0x40e98FeEEbaD7Ddb0F0534Ccaa6174
27eA10187e

0x140c9Ab92347734641b1A7c124ffDeE5
8c20C3E3

0x684d4b58Dc32af786BF6D572A792fF7
A883428B9

0xBC3e5e8C10897a81b63933348f53f2e0
52F89a7E

0x5Af75eAB6BEC227657fA3E749a8BFd5
5f02e4b1D

0xBCA02B395747D62626a65016F2e64A
20bd254A39

0x4C198B3B5F3a4b1Aa706daC73D826c
2B795ccd67

0xCd7eC020121Ead6f99855cbB972dF50
2dB5bC63a

0xbdE2Cc5375fa9E0383309A2cA31213f2
D6cabcbcd

0xD3C611AeD139107DEC2294032da391
3BC26507fb

0xB72334cB9D0b614D30C4c60e2bd12fF
5Ed03c305

0x8c7235e1A6EeF91b980D0FcA083347F
Bb7EE1806

0x1bb0970508316DC735329752a4581E0
a4bAbc6B4

0x1eB27f136BFe7947f80d6ceE3Cf0bfDf9
2b45e57

0xCd1a4A457cA8b0931c3BF81Df3CFa22
7ADBdb6E9

0x09278b36863bE4cCd3d0c22d643E806
2D7a11377

0x660BfcEa3A5FAF823e8f8bF57dd558db
034dea1d

0xE9bc552fdFa54b30296d95F147e3e028
0FF7f7e6

0x30a822CDD2782D2B2A12a08526452e
885978FA1D

0xB4a862A81aBB2f952FcA4C6f5510962
e18c7f1A2

0x0e8C1E2881F35Ef20343264862A242F
B749d6b35

0x9271EDdda0F0f2bB7b1A0c712bdF8db
D0A38d1Ab

0xe69753Ddfbedbd249E703EB374452E7
8dae1ae49

0x2290937A4498C96eFfb87b8371a33D1
08F8D433f

0x959c4CA19c4532C97A657D82d97acC
BAb70e6fb4

0x52207Ec7B1b43AA5DB116931a904371
ae2C1619e

0x9eF42873Ae015AA3da0c4354AeF94a1
8D2B3407b

0x1542368a03ad1f03d96D51B414f47389
61Cf4443

0x21032176B43d9f7E9410fB37290a78f4f
Ed6044C

0xA4B2Fd68593B6F34E51cB9eDB66E71
c1B4Ab449e

0x55CCa2f5eB07907696afe4b9Db5102b
cE5feB734

0xA5A023E052243b7cce34Cbd4ba20180
e8Dea6Ad6

0xD90071D52F20e85c89802e5Dc1eC0
A7B6475f92

0x1512fcb09463A61862B73ec09B9b354
aF1790268

0xF302572594a68aA8F951faE64ED3aE7
DA41c72Be

0x723a7084028421994d4a7829108D63a
B44658315

0xf03AfB1c6A11A7E370920ad42e6eE735
dBedF0b1

0xEB0bAA3A556586192590CAD296b1e4
8dF62a8549

0xD5b58Cf7813c1eDC412367b97876bD
400ea5c489